Threat evolution in Q2 2018

GROUP-IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3
Executive summary 4
Forecasts for Q3 2018 8
APT targeting the Financial Sector 9
Financial threats 14
Malware for Android 15
Banking threats for PC 17
Attacks on ATMs and POS terminals 22
State-sponsored APT groups 24
Threats to blockchain projects and cryptocurrencies 34
Data leakage 38

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the USA, Canada and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by government and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the Financial Sector

- The Silence group continued its attacks on financial institutions and companies. The hackers distributed phishing emails with exploits for the CVE-2017-11882 and CVE-2018-8174 vulnerabilities. Successful exploitation of these vulnerabilities enables hackers to download additional malicious software on the victim's machine, for example, their unique backdoor.
- The Cobalt group conducted a series of large-scale attacks on financial institutions. Group-IB identified five malicious campaigns, which involved both their JavaScript backdoor, and unique Recon backdoor CobInt. The emails purported to be from Apple, Kaspersky Lab, the European Central Bank, the Federal Financial Monitoring Service of the Russian Federation, and Diebold Nixdorf.
- We also identified a malicious campaign launched by Cobalt imitators. Group-IB specialists detected malicious emails downloading Cobalt Strike software.
- In May, hackers infiltrated the IT systems of Banco de Chile (Chile) and stole funds via SWIFT. The attack destroyed 9,000 workstations and 500 servers. Flashpoint analysts said that the employed malware is a modified version of the Buhtrap malicious component known as MBR Killer, leaked to the underground in February 2016. Group-IB experts believe that the Lazarus group may have been involved in the attack.
- Unknown hackers attacked Malaysia's central bank Negara.
- Multiple banks in Mexico, including Grupo Financiero Banorte, Banco del Bajio SA and Banco del Ejercito, have experienced large, unauthorized cash transfers after threat actors gained access to their systems.
- Two Canadian banks, Bank of Montreal (BMO) and Canadian Imperial Bank of Commerce-owned Simplii Financial, have disclosed that cyber criminals may have stolen sensitive data of their customers.
- Hackers conducted a phishing campaign against hotel services in Europe, in particular, targeting Airbnb customers.
- The hacking group behind the Olympic Destroyer malware that hit the opening of the Winter Olympics in South Korea earlier this year has resurfaced in a campaign that is targeting financial organizations in Russia, and biological and chemical threat prevention laboratories in the Netherlands, Germany, France, Switzerland, and Ukraine.

Financial threats

- In Russia and the CIS, clients of banks were attacked by the following Android Trojans: Asacub, Agent.sx, FlexNet, Limebot and Agent.BID. The Agent.BID Trojan has returned to the market after a long break.
- Clients of banks in the CIS were attacked by RTM and Buhtrap malware;
- In Russia and the CIS, Android users are being attacked by the Asacub, Agent.sx, FlexNet, Limebot and Agent.BID mobile Trojans. Agent.BID appears to have resumed after a long break.
- Clients of banks in the CIS were attacked by RTM and Buhtrap malware;
- A number of western banks, are continuously under the threat of attacks using the Red Alert Android Trojan. Its author constantly expands the target list, which makes this tool even more popular among hackers.
- Another popular tool is the AndyBot Android banking Trojan, which was updated to include fake pages for more than 130 banks in the US, Australia and Europe.
- A new Android banking Trojan called "Nero" appeared on sale. It includes fake pages for 200 banks and cryptocurrencies worldwide;
- The Gozi/Ursnif banking Trojan continued attacking banks in Australia, Japan and Italy, and Bulgaria;
- The Toplel criminal group (aka Dimnie) continued to attack clients of Russian banks;

- Researchers discovered a toolkit called Rubella Macro Builder, which is designed to automatically create Microsoft Office documents with built-in malicious macros that attackers can distribute via email attachments.
- In Russia, attacks on ATMs using a new program were detected. The MoneyTaker group is purportedly to have been behind the attack;
- The source code of the notorious TreasureHunter point-of-sale malware was posted on an underground forum;
- Hackers began to sell a malicious program for ATMs called "Cutlet v2";
- Attacks on ATMs using the "Cutlet Maker" malicious program were detected in Portugal and Argentina;
- Attackers distributed NetWire RAT with spear-phishing emails;
- Researchers discovered a new banking Trojan for Windows, dubbed Osiris, which operates using Tor, can bypass proactive defense and has anti-sandbox/VM/debugger capabilities.
- In April, security specialists spotted a new strain of malware targeting ATMs. Group-IB specialists have analyzed the tool, which appears to be based on ATMRipper source code. We named the new program ATMRipper2.
- A zero-day exploit for the bank processing system "Tieto Card Suite" went on sale.
- A Japanese Android banking malware "Sagawa" was discovered and analyzed.
- TinyNuke continued to attack French banks;
- ICEDID continued attacking the United States, Canada and the United Kingdom, using Emotet tool for delivery;
- Trickbot attacked financial institutions in the US, Canada, France, Australia, Spain, Germany;
- Qbot injections targeted financial institutions in the Netherlands, the USA, and Canada;
- The Gootkit banking Trojan was used to attack banks in the UK and Australia;
- In Q2 2018 Group-IB did not detect any attacks using Dridex or Ramnit;
- In May, a new banking Trojan called BackSwap attacked banks in Poland. The malware uses an innovative technique to manipulate the browser: instead of using complex process injection methods to monitor browsing activity, the malware injects malicious JavaScript into the web page, either via the browser's JavaScript console or directly into the address bar.

Threats to blockchain projects and cryptocurrencies

- Indian cryptocurrency exchange Coinsecure has announced the theft of nearly $3.3 million in bitcoin.
- Hackers used the man-in-the-middle attack to gain access to a DNS server to steal funds from MyEtherWallet.com users.
- Taylor, a cryptocurrency trading platform, has been hacked for about $1.5 million.
- Verge, a cryptocurrency service, was the victim of a '51 percent attack' twice. $2.78 million was stolen.
- Hackers conducted a targeted attack on OKEx, a Chinese bitcoin exchange, by exploiting CVE-2018-10299 vulnerability.
- Bitcoin Gold (BTG) appears to have been the target of a 51 percent attack, leading to the theft of approximately $17.5 million from cryptocurrency exchanges.
- A cryptocurrency trading platform "Taylor" suffered an attack, resulting in the theft of $1.5 million.
- ZenCash (ZEN), a platform designed for secure communications and private economic activity, saw its network suffer a 51% attack, which resulted in a loss of about $550,000 worth Zen crypto tokens.
- The Litecoin Cash network was recently found under 51% attack.
- A targeted attack was conducted on the South Korean currency exchange "Coinrail", which resulted in the theft of about $40 million.

- The Lazarus group continued attacks on clients of cryptocurrency exchanges. Purportedly, they hacked Bithumb, the South Korea's largest cryptocurrency exchange, stealing around $31 million worth of cryptocurrencies.

Data leakage

- In May 2018 researchers revealed and reported on how ViewFines, an online traffic fines payments website for South Africans, was the source of the leak of almost 1 million personal records of South Africans.
- Bank of Montreal and Canadian Imperial Bank of Commerce said that cyber attackers may have stolen the data of nearly 90,000 customers in what appeared to be the first significant assault on financial institutions in the country.
- FireEye experts discovered data of over 200 million Japanese users to be sold on a Chinese underground hacker forum.
- Security researchers discovered that over 43 million email addresses have leaked from the command and control server of the Trik spam botnet.

Threats to the Government sector

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies.

In Q2 2018 the following active APT campaigns were detected:

- Hackers conducted targeted attacks against the CIS countries using the Buhtrap loader.
- A new APT group named Thrip conducted targeted attacks on satellite operators, telecommunications companies and defense contractors in the United States and Southeast Asia.
- The OceanLotus group attacked users in Southeast Asia and China, using exploits for the CVE-2017-11882 and CVE-2017-0199 vulnerabilities.
- The APT37 hacker group attacked South Koreans as part of the Operation Baby Coin. Also, the group is believed to have been behind the attacks on South Korea's facilities using NavRAT.
- The cyber espionage group known as "Tick" has been targeting a secure USB drive built by a South Korean defense company.
- The Mustang Panda group attacked Mongolia as part of the campaign that began in 2017.
- The Charming Kitten group continued to conduct watering hole attacks against the US and Germany.
- Researchers discovered a new hacker group named Orangeworm, which has been targeting healthcare providers and associated organizations since 2015.
- The APT28 group conducted a number of attacks, using the Dynamic Data Exchange (DDE) exploit technique to deliver Zebrocy and Koadic Trojans, and hijacked the legitimate LoJack software.
- Chinese government hackers have compromised the computers of a Navy contractor, stealing massive amounts of highly sensitive data.
- The MuddyWater APT group continued to launch phishing campaigns targeting organizations in Turkey, Iraq and Pakistan. In May security researchers discovered another potential MuddyWater campaign, using Powershell-based PRB-Backdoor.
- The Iron Tiger group hit a national data center in Mongolia.
- A new dangerous malware called MirageFox, used by the APT15 hacking group, was discovered.
- An APT group, tracked as Andariel Group, leveraged an ActiveX zero-day vulnerability in targeted attacks against South Korean entities.
- The Kimsuky hacker group attacked South Korea as part of Operation Onezero.

- The Lazarus group has returned with new campaigns. One of the recent attacks targeted members of a G20 Financial Meeting. The hackers are currently using the updated versions of Joanap and Brambul Trojans, as well as a new malware dubbed Typeframe.

Forecasts for Q3 2018

- Silence will be the most active group targeting financial institutions. It has successfully attacked ATMs and card processing. In recent attacks, they used improved tools.
- The Cobalt group will continue their attacks. Following the example of the Anunak group, they may begin to attack systems related to POS terminals, and temporarily stop their attacks on banks. Their key target will be companies and institutions outside the CIS.
- Source code for the point-of-sale malware called TreasureHunter was found on underground forums. This may spawn a wave of new PoS threats, and, possibly, provoke a short-term growth of incidents due to its active use by less skilled hackers.
- The Toplel group will continue to attack Russian entities.
- Clients of Russian-speaking banks will be attacked using RTM and Buhtrap malware.
- During the 2018 FIFA World Cup Russia, the number of attacks on Russian companies will increase, both by state-sponsored and financially motivated hackers. The goal of state-funded attackers can be sabotage. Financially motivated hackers are expected to conduct phishing attacks on individuals in order to obtain their bank card data and infect POS terminals.
- We believe that a new Android banking Trojan "Nero" will be actively used to commit financial fraud. It has a wide range of functions, and, more importantly, an extensive set of web fakes, so that the Trojan customers can choose their target of interest in almost any country.
- The Nero, Red Alert and Andybot Trojans will be used to attack Android devices outside Russia, and in Russia hackers will use Asacub, Flexnet and Agent.BID.
- After successful testing of the Cutlet v.2 Trojan, this tool may be used in attacks on Wincor ATMs in the near future.
- Gozi, Trickbot, Qbot and ICEDID will remain the most active banking Trojans outside Russia.
- We will continuously observe the increasing trend of cyber-attacks on cryptocurrency exchanges. Currently, we see that cryptocurrency wallets have been added to the majority of banking Trojans as targets.
- The North Korean Lazarus group will attack both banks and cryptocurrency exchanges, using new malicious programs from its arsenal.

APT targeting the Financial Sector

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks from the Cobalt hacker group	Kazakhstan, Russia, Global	CP-1438-44 - CP-1438-48	2016

In spite of the arrest of its leader in March 2018, the Cobalt group continued active attacks in Q2:

- On May 21, the Cobalt group sent out malicious emails posing as Apple. The letters contained a link to a malicious RTF file with exploiting the vulnerabilities CVE-2017-0199, CVE-2017-8570, CVE-2017-11882, CVE-2018-0802. After successful exploitation of the vulnerability, a loader of the Cobalt JavaScript backdoor was loaded.
- On May 23, Cobalt attacked financial institutions posing as Kaspersky Lab. The subject of these letters was "Technical Support". The emails included a link to the unique new Recon (CobInt) backdoor, first observed in the wild in February 2018.
- On May 28, Cobalt sent malicious emails to banks acting as the European Central Bank. The emails contained a link to a file masqueraded as a document describing financial risks. The Microsoft Word lure document triggered the exploitation of the CVE-2017-11882 vulnerability. Following this, the malware created several files: a .bat script, a Connection Manager service profile, a decoy document (a blank document). Once executed, the .bat script closed the current document and opened the decoy one. Following this, it run cmstp.exe, a command-line program used to install Connection Manager service profiles – that is how the malware bypasses whitelisting and security controls. As a result, the SCT script was loaded, which is a loader of the Cobalt JavaScript backdoor.
- On June 7, the Cobalt group sent malicious emails to Russian banks acting as the Federal Financial Monitoring Service. The letters contained a link to a malicious document exploiting the CVE-2017-11882 and CVE-2018-0802 vulnerabilities. The exploitation will result in installation of a loader for the Cobalt JavaScript backdoor.
- On June 19, Cobalt conducted an attack on banks acting as Diebold Nixdorf. The detected letters were in Russian and English. They contained recommendations for updating ATM software and a link to the 'instructions'. The link downloaded a document with a macro. The macro saves the Connection Manager service profile on the disk and starts it. The profile contains a link for downloading the XML file, which is a dropper of the Cobalt JavaScript backdoor, which also contains a decoy document. Once executed, the dropper saves the backdoor under names of different length with the .txt extension.

Criminal group	Regions attacked	Detection
Toplel	Russia	2015

A criminal group called Toplel, which was actively attacking customers of Russian banks in 2014-2015, returned to the spotlight and renewed its attacks on Russian companies and banks in late October 2017. In Q2 2018 we also observed their activity. They continued to use the Symmi backdoor and Pony malware.

We believe that this may lead to a rise in the number of thefts from legal entities via online banking systems; targeted attacks on banks are also possible.

It is interesting to note that some security companies call this criminal group "Dimnie".

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks by a fake Cobalt group		CP-1699	June 2018

On June 4, 2018, a phishing campaign with Korean-language emails was discovered. Unknown threat actors masqueraded as the Cobalt hacker group. Emails purported to be from international delivery company FedEx. They contained a link to a document with a macro. When the macro is executed on the victim's machine, a

trial version of Cobalt Strike malware is installed along with the EICAR file (a standard file used to check if the antivirus is running). Group-IB notes that despite their similarity to Cobalt emails, this attack was conducted by some other hackers who probably decided to pose as the famous cybercriminal group.

APT name	Regions attacked	Related notifications	Operation start
Silence	CIS	CP-1645-2	May 2018

On May 24, Group-IB specialists detected a phishing campaign targeting financial institutions and companies conducted by the Silence group. The group sent emails written in Russian with a malicious file named "Договор.doc" (Agreement.doc) attached and the subject "Корреспондентский счет" ("Correspondent account").

After the file is opened, the CVE-2017-11882 vulnerability is exploited, and the mshta.exe application is launched. The downloaded HTA script contains an encrypted PowerShell script. The decrypted script loads, saves and launches an executable file. This file, classified as Silence.Downloader, is designed to download and run additional executable files. Prior to connecting to the server, the loader saves its copy and ensures persistence on the system by creating a registry value that contains the name of its copy. Analysis of their previous attacks shows that Silence.Backdoor can be loaded and launched at the next stage.

The server that was used to conduct the attack, contains a network object that returns a VBScript for exploiting the CVE-2018-8174 vulnerability in Internet Explorer and loading the HTA downloader of the Silence.Downloader program. The vulnerability, also known as Double Kill, affects the latest version of Internet Explorer and applications that use the IE kernel. Exploiting the vulnerability can allow remote attackers to execute code with the same privileges as the current user and gain control over the system.

The Silence hacking group has been active since 2016, primarily targeting financial institutions in the CIS.

APT name	Regions attacked	Operation start
Targeted attack on Malaysia's central bank Negara	Malaysia	March 2018

On March 27, 2018, Malaysia's central bank Negara said it was the victim of a cyber-attack in which hackers sought to steal money through SWIFT. Unauthorized transactions were stopped through prompt actions of the bank's employees. Bank Negara Malaysia said no funds were lost in the incident.

APT name	Regions attacked	Operation start
Targeted attacks on banks in Mexico	Mexico	April 2018

In April 2018, unknown hackers attacked several large banks in Mexico. During this series of attacks, consumers could see a slowdown in transfers. The Banorte bank incurred the largest losses, with about $7.7 million diverted from its accounts. BanBajio is another major bank which was reportedly hit by the cyberattacks. Experts estimated the banks' losses at $8.2 million. Banco del Ejercito was also compromised.

Banorte Bank publicly acknowledged that breaches had taken place. The bank said that the transfers hit accounts of the bank in the central bank and no clients were affected. BanBajio denies the reports.

Hackers reportedly sent hundreds of false orders to move amounts from banks to fake accounts in other banks, and accomplices then emptied the accounts in cash withdrawals in dozens of branch offices.

APT name	Regions attacked	Operation start
Targeted attacks on Canadian banks	Canada	May 2018

In late May 2018, unknown hackers broke through security at two of Canada's biggest banks, Bank of Montreal (BMO) and Simplii Financial, which is a subsidiary to CIBC (Canadian Imperial Bank of Commerce). Fewer than 50,000 clients at Bank of Montreal and approximately 40,000 Simplii Financial clients were affected. The perpetrators allegedly sent emails to the banks and media, threatening to publish that data online unless the banks pay them $1 million in XRP. To prove the legitimacy of the threat, the email included unencrypted customer names, social insurance numbers and answers to security questions that allegedly were stolen. The email also outlined how the attackers were able to breach bank defences. Details on the methods and tools used by attackers are not disclosed.

APT name	Regions attacked	Related notifications	Operation start
Phishing campaign focused on hotel services	Europe	CP-1691	May 2018

In May 2018, hackers launched a phishing campaign, targeting hotel services in Europe. They sent phishing emails containing a link to a phishing page. The fake website mimicked a popular European hotel service. After entering login credentials, the victim was redirected to the page of a fake Adobe Flash update. This website was was running on the domain get-adope[.]eu. The script embedded into the website launched an HTML file in the /dir/ directory. This file sent a GET request and downloaded a ZIP archive via link to the public file-sharing service and shortened using the public service bit.ly.

If a user downloads the ZIP archive, extracts and launches the JavaScript file, then his computer will be infected with malicious software. The malware communicates with the C&C server and sends information about the infected system. Following this, the executable file is launched, which starts several Internet Explorer processes and injects other executable files into these processes. One of the executables is a legitimate password recovery tool that reveals the passwords stored by the web browsers: WebBrowserPassView v1.86 by NirSoft. The other file is a banking Trojan with a form grabber functionality that is able to steal data from forms filled by the user on the target websites.

The target list included hotels, hotel services, financial institutions and banks: the threat actor purportedly tried to steal data of bank accounts to which hotels accepted payments.

Also in the middle of May, 2018, Airbnb customers were hit with phishing scams. Airbnb announced to its users that changes to their policies will go into effect on 25 May 2018. Scammers then mimicked that email distribution with a specious email asking customers to update their account information.

Pretending to be from Airbnb, the hackers sent phishing emails, mainly to businesses' email accounts. The hackers took the time to make the emails look like they were from Airbnb and even included its logo.

The phishing emails noted that Airbnb had updated its privacy policy. The recipients were told they had to accept the new privacy policy before they could log back into the Airbnb website. To accept it, they had to click a link in the email. The link then takes you to a phishing website, where the victims were instructed to enter their account credentials, payment card information, and other personal data. If they did so, it fell right into the cybercriminals' hands.

The stolen data was used to withdraw funds from the victims' accounts or further sold.

APT name	Regions attacked	Operation start
Targeted attack on Banco de Chile	Chile	January 2018

On May 24, 2018, Banco de Chile, the second largest bank in the country, was hit by a major malware attack that breached its computer systems shutting down bank operations. Although bank operations were cancelled, internet portals, mobile applications and ATMs were not affected and were secure to use.

Security researchers at Trend Micro reported that a new variant of the disk-wiping malware KillDisk, tracked as KillMBR, was used in the attacks. The malware overwrites the Master Boot Record (MBR) to ensure that the operating system cannot function anymore after restart. KillDisk was compiled using the open source application Nullsoft Scriptable Install System (NSIS).

Hackers used the disk-wiping malware to sabotage hundreds of computers at the bank to distract staff while they were attempting to steal money via the bank's SWIFT money transferring system. Banco de Chile admitted that hackers stole $10 million during the May 24 incident. The bank is taking legal action against an unidentified correspondent in Hong Kong in an attempt to retrieve the stolen funds. According to a screenshot of private IM conversations posted on a Chilean forum, the alleged "virus" crashed over 9,000 computers and over 500 servers.

Forensic investigation has not yet identified the group behind the attack. Researchers link this attack to Lazarus, Black Energy, Buhtrap, or Cobalt threat actors.

APT name	Regions attacked	Operation start
Olympic Destroyer	Russia, France, Netherlands, Switzerland, Germany, Ukraine	May 2018

In May-June 2018 experts at Kaspersky Lab uncovered new cyber-attacks involving Olympic Destroyer. The discovered spear-phishing were targeting financial organizations in Russia, and biological and chemical threat prevention laboratories in France, Netherlands, Switzerland, Germany, Ukraine, and Russia.

Authorities have not identified any suspects, though cyber security firms have speculated that Chinese-speaking APTs, North Korean Lazarus group or Russian-speaking threat actor APT28 could be behind the hack.

Some decoy documents were related to the Salisbury attack investigation. Some other spear-phishing documents were in perfect Russian, suggesting that they were probably prepared with the help of a native speaker and not automated translation software and targeted Russian-speaking victims.

Phishing emails contained attached files with a heavily obfuscated macro. Its purpose is to execute a PowerShell command. This VBA code was obfuscated with the same technique used in the original Olympic Destroyer spear-phishing campaign.

The macro started an obfuscated PowerShell script, which was used to decrypt additional payload downloaded from Microsoft OneDrive. This script disabled PowerShell script logging to avoid leaving traces. The final payload was the PowerShell Empire agent.

PowerShell Empire is a free and open-source framework that allows fileless control of the compromised hosts and is widely used in legitimate penetration tests.

Kaspersky Lab experts assume that attackers used compromised websites to host and manage malicious software.

Financial threats

GROUP IB

GLOBAL CYBER SECURITY COMPANY

Malware for Android

Malware name	Regions attacked	Detection
Red Alert	Global	May 2017

Currently, the Red Alert Android banking Trojan is quite popular and often purchased on underground resources. At a relatively low price, the client gets an effective malware with a large set of fake pages for attacks on banks worldwide, as well as for cryptocurrency wallets. The author nicknamed Sochi is constantly updating the malware - in March 2018 Red Alert v2 was released. The list of attacked banks is expanding as well. With a list of over 200 targets, criminals do not limit themselves to banking apps, but increase their non-banking targets including mail clients, cryptocurrency apps and various payment systems.

Malware name	Regions attacked	Detection	Related notifications
AndyBot (Gustuff Bot)	Global (except the CIS)	2017	CP-1643-2

AndyBot has standard functionality of an Android Trojan: manipulates SMS messages, performs calls and USSD requests, displays fake pages, locks the device and uploads photos from infected devices.

In April 2017 its author released an updated version with an extensive list of web injects for banks in the US, Australia, and Europe. The target list includes over 130 organizations. The monthly rental price is $800.

Malware name	Regions attacked	Detection
Agent.BID	Russia	August 2015

Agent.BID is an Android banking Trojan with web injection functionality. We have not observed its activity since late 2016. However, in Q2 2018 it again became active. In June, Group-IB analysts revealed that its botnet included about 100,000 infected devices and continued to grow. The Trojan enables criminals to display fake web pages for various banking applications in order to steal online banking credentials and bank card data.

Malware name	Regions attacked	Detection
FlexNet	Russia	2014

The Trojan requests device administrator privileges. The text of the request is masqueraded as the Google Play Agreement, which distracts the user and leads to the confirmation of rights.

On command from the C&C server the application can:

- change the address of the C&C server
- send an SMS message to the specified number
- send spam messages with the specified text
- forward text messages to the C&C server
- reply to SMS messages and delete them to hide from the user
- run USSD requests
- create a scheduled task - setting up a command template for new bots, taking into account the operator and the country.

Also, Group-IB specialists determined that authors added phishing dialogs disguised as popular applications to the recent version of FlexNet. The phishing windows are designed to receive victim's bank card data.
The following fake dialogs were discovered:
AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard

ВТБ24
Sberbank
Uber

Threat name	Detection	Regions attacked
Agent.sx	2015	Russia

Criminals use this banking bot, which has capabilities to send and intercept SMS messages, to perform unauthorized money transfers through SMS banking. Developers have added an auto-reply function to the malware control panel, which enables attackers to send messages with transfer confirmation automatically. The program also has the functionality to parse SMS messages in order to obtain victim's card balance. This parser can be customized for any bank. The Trojan also has capabilities to collect bank card data using a Google Play phishing dialog.

Threat name	Detection	Regions attacked
Gugi/Limebot/Lipton	August 2016	Russia

The Trojan displays a phishing dialog box on the top of official applications in order to steal online banking credentials and credit card data. In addition to that, the malware is able to capture SMS messages and contact lists, run USSD requests and send SMS on command from the C&C server. The Trojan spreads via SMS spamming and uses fake windows to capture data.

Threat name	Detection	Regions attacked
Asacub	2014	Russia

Once the victim's device is infected, the Trojan starts sending messages to the entire contact list, and sends SMS to short number 900 in order to find out the balance of the victim's bank card (in the event the victim is a client of Sberbank).

It also has the following functionality: sends a list of installed applications, the browsing history and contact list to the C&C server, sends SMS messages to the specified number, downloads the history of messages to the C&C server, displays phishing pages over legitimate applications, forwards calls to the specified number, sends USSD requests, downloads files from a specified link and installs them.

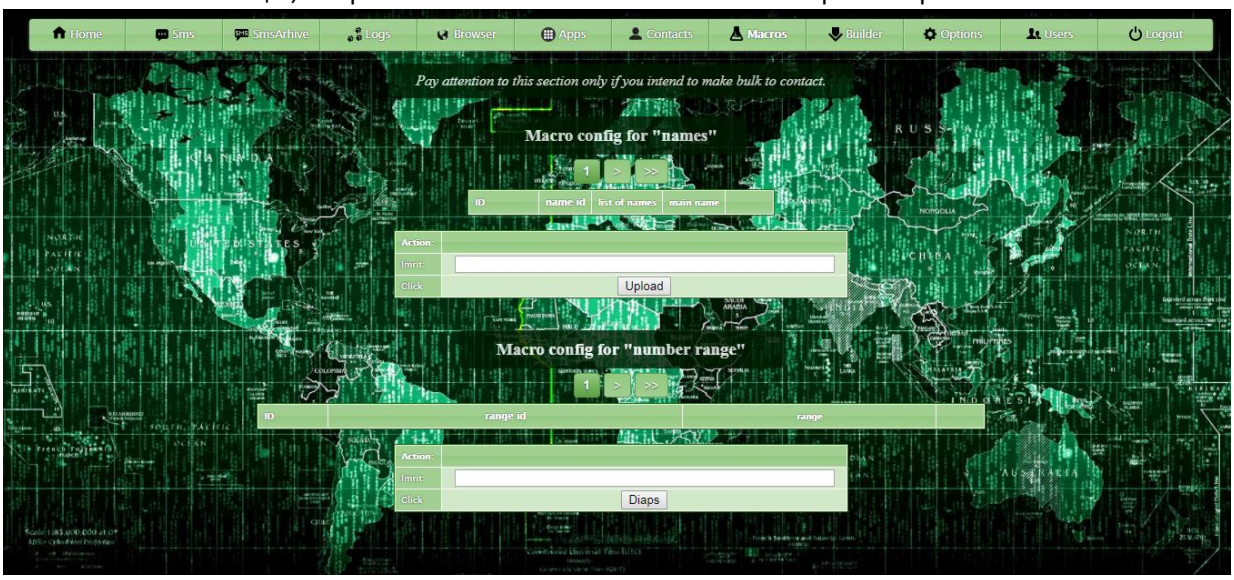
Malware name	Regions attacked	Detection	Related notifications
Nero banker	Global (except CIS)	April 2018	CP-1681

On April 4, 2018, a user nicknamed Nero published an ad for a new Android Trojan called Nero banker. This malware is designed to perform multiple tasks as follows:

- Intercept and send SMS messages
- Perform web injections (show fake pages) – the author says the malware includes about 200 ready-to-use web fakes for banks in Australia, Australia, Canada, Czech Republic, Germany, Spain, France, Hong Kong, India, Japan, Poland, Romania, Turkey, Ukraine, USA, South Africa, as well as for a number of cryptocurrencies;
- Get a contact list, a list of SMS messages, a list of installed applications
- Make and forward calls
- Send USSD requests
- Send SMS spam
- Collect bank card data
- Show fake PUSH notifications

- Protect against standard security tools
- Survive factory data reset
- Block selected applications
- Customizable APK builder with extensive functionality
- Promptly clean APK files to avoid AV detection
- Support for backup URLs in case the main URLs are blocked
- Encryption of important data

Nero banker is leased for $1,500 per month. A screenshot of the control panel is presented below:



Malware name	Regions attacked	Detection	Related notifications
Sagawa	Japan	March 2018	CP-1698

In March 2018, specialists discovered phishing SMS messages targeting users in Japan. The link led to the Sagawa banking malware.

The Trojan is able to receive the victim's contact list and send it to the C&C server, set the device to silent mode, collect information about the device, intercept SMS and MMS messages and change the contact list, as well as to install fake applications instead of legitimate ones. The Trojan primarily targets financial applications.

Banking threats for PC

Malware name	Regions attacked	Detection
ICEDID	USA, Canada, UK	2017

Security specialists originally discovered this banking Trojan in late 2017. This malicious program may be employed to steal financial information and conduct targeted attacks. Researchers revealed that attackers used another Trojan, Emotet, to spread ICEDID.

ICEDID has a modular structure and incorporates techniques of the infamous Zeus Trojan, including web injections, the ability to embed code into processes, data theft. One of its distinctive features is the ability to deploy a proxy server on an infected machine and redirect all Internet traffic using this server.

The identified ICEDID samples are designed to target the following banks in the US, Canada and the UK:

HSBC Bank
JPMorgan Chase
Citibank
Bank of America
Blockchain.info
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Huntington Bancshares, Inc.
Chase Bank
Charles Schwab Corporation
NETELLER
Canadian Imperial Bank of Commerce (CIBC)
Wells Fargo
Fifth Third Bank (53 bank)
Capital One
KeyBank
American Express
Halifax
TSB Bank
PNCbank
Mandtbank
Post Oak Bank (US)
USAA
Unionbank (US)
USBank

Malware name	Detection	Countries attacked
Qbot	2009	USA Netherlands Canada

Discovered in 2009, the QakBot or Qbot banking Trojan has significantly evolved over time. The malware features a modular design, is multithreaded, and includes components designed to steal keystrokes, online banking credentials, digital certificates, authentication tokens, and cookies, implement a backdoor, and create a SOCKS proxy. It also has the functionality to bypass AV solutions. The program is primarily used to target businesses, stealing money from their bank accounts. QBot is able to spread like a worm by self-replicating through shared drives and removable media.

Group-IB specialists retrieved a configuration file of the last QBot version. According to this file, the malware is designed to attack the following targets:

ABN AMRO Bank
Citibank
Huntington Bancshares, Inc.
Toronto-Dominion Bank (TD BANK)
Bank of America
First Citizens Bank
Citizens Financial Group
First Tennessee Bank
Banco Bilbao Vizcaya Argentaria (BBVA)
Eastern Bank
Fifth Third Bank (53 bank)
FirstMerit Bank
JPMorgan Chase
KeyBank
Suntrust
Scotiabank
Usbank
Capital One
Frostbank
PNCbank
Mandtbank
Websterbank
Wells Fargo

Malware name	Regions attacked	Detection
Gozi (ISFB, Ursnif)	Japan, Australia, Bulgaria, Italy	2007

The Gozi samples identified in Q2 attack banks in Australia, Japan and Italy. Its target list also includes two Bulgarian banks.

Gozi's targets are as follows:

Shinkin bank (Japan)
The Bank of Tokyo-Mitsubishi UFJ
Aeon Bank (Japan)
Credit Saison (Japan)
Move Bank (Australia)
Blockchain.info
Australian Military Bank
Customs Bank
Rakuten
BankVic (AU)
Daishi bank (JP)
Firefighters Mutual Bank (AU)
Hokkoku bank (JP)
Resona Bank (JP)
Teachers Mutual Bank (AU)
Tsukuba bank (JP)
Awa bank (JP)
Yamagata Bank (JP)
B&E Personal Banking
Bananacoast Community Credit Union (BCU)
Hume Bank
Adelaide Bank
First Option Credit Union
IMB Bank
Commonwealth Bank of Australia
National Australia Bank
Unicredit Bulbank (BG)
Regional Australia Bank
Societe Generale Експресбанк (BG)
Macarthur Credit Union (AU)
Endeavour Mutual Bank (AU)
Bank Poste
BNL (it)
ING (it)
Unicredit (it)
Banco BPM (it)

Malware name	Regions attacked	Detection
Trickbot	USA, Canada, France, Australia, Spain, Germany	Fall 2016

Trickbot is a banking Trojan hat has a similar functionality to the Dyre (Dyreza) malware.

The samples detected in Q2 2018 are targeting the following banks:

Fifth Third Bank (53 bank)
Caisses Desjardins
Citibank
Allianz Bank (FR)
Bank of America
Amazon.com, Inc.
American Express
Australia and New Zealand Banking Group
Toronto-Dominion Bank (TD BANK)
Bancofar
Bancopopular
Sabadell
BB&T Bank
Sparda-Bank
Deutschen Bank
Capital One
Sparda Bank
Banque Populaire (FR)
Banco Bilbao Vizcaya Argentaria (BBVA)
Banco Mare Nostrum, S.A.
Bank of Montreal
The National Bank of Canada
Caixa
Cetelem
Chase Bank
Canadian Imperial Bank of Commerce (CIBC)
Comdirect Bank AG
Commerzbank
Wells Fargo
Credit Agricole
Frostbank
HSBC Bank
Intesa
Kutxa bank
Sparkasse
Commonwealth Bank of Australia
NETELLER
Suntrust
Usbank
Scotiabank

Lloyds Bank

Threat name	Detection	Countries attacked
TinyNuke (aka NukeBot)	2017	France

Examples of attacked banks:
Crédit Industriel et Commercial
Credit Agricole
Creditmutuel
Bnpparibas
LCL
Banquepopulaire

Threat name	Detection	Countries attacked
Gootkit	2014	UK, Australia

Gootkit banking Trojan has the functionality to record video, take screenshots, change web pages using web injections, redirect victims to phishing resources, install keylogger, and block URLs.

In Q2 2018, researchers discovered samples attacking the following banks:

Bank of Scotland
Bendigo and Adelaide Bank
Lloyds Bank
Ulster Bank
Barclays
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Blockchain.info
HSBC Bank
Danske Bank
Halifax
National Australia Bank
TSB Bank
Westpac
Tesco Bank
Australia and New Zealand Banking Group

Threat name	Detection	Regions attacked
RTM	2015	Russia

The modular Trojan is written in Delphi. Based on its functionality, the Trojan is designed to attack RBS and payment systems. The last detected sample of the Trojan searched for the following RBS systems on the infected machine: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, VTB24.

The RTM group has the main control panel and a separate Proxy panel for banks with which they use a specific technique – all requests are forwarded to phishing servers, where traffic is proxied.

Threat name	Detection	Related notifications	Regions attacked
Rubella Macro Builder	2018	CP-1689	Global

Rubella Macro Builder (RMB), a toolkit creating DOC and XLS files with embedded malicious macros, is now being offered on a hacker forum and has already been detected in downloads of such banking Trojans as Panda Banker and Gootkit. It infects devices through email attachments. RMB acts as first-stage loader to subsequently download and install other malware.

Its latest version is 1.4 and the developer continues to upgrade the tool. Its relatively low price –$500 per month and $1250 per 3 months – can make it widely popular.

Threat name	Detection	Related notifications	Regions attacked
Netwire RAT	2012	CP-1683	Global

In April 2018, a phishing campaign distributing Netwire RAT was detected. The campaign began on March 2, 2018 and lasted until at least April 12.

The letters have different subjects and content, but the same attachment. Some malicious emails are associated with SWIFT. Once opened, the Microsoft Word document downloads a remote RTF file. It contains a number of objects, one of which is an Excel file with a malicious macro. The macro loads the .VBS script and launches it. This results in downloading an executable file, which appears to be a wrapper: its resources contain the Netwire.RAT Trojan, which is unpacked during execution and launched. In addition, the wrapper is well-equipped with anti-debugging and anti-virtual machine protection.

This remote access Trojan has capabilities to collect data about the infected system, collect user accounts in various programs (browsers, e-mail clients), provide remote access to the infected system, intercept and store keystrokes, download and execute files on command.

Threat name	Detection	Related notifications	Regions attacked
Osiris	April 2018	CP-1682	Global

On April 3, 2018, an ad for a new banking Trojan called Osiris, appeared on an underground forum. The malware is designed to gain access to confidential information stored or processed in online banking systems. This tool is delivered through the "malware-as-a-service" model. The specific feature of the Trojan is that it operates using Tor.

Threat name	Detection	Related notifications	Regions attacked
0day exploit for Tieto Card Suite	April 2018	CP-1685	Global

In April, a 0-day exploit for Tieto Card Suite went on sale on an underground forum. Tieto Card Suite is a banking card processing solution by the Finnish company Tieto. Information about a dozen Russian and foreign banks using the Tieto Card Suite solution was obtained from open sources. The vulnerability type is RCE (remote code execution). The stated cost is $5,000.

Threat name	Detection	Related notifications	Regions attacked
RTM hacker group	2015	CP-1709	Russia

In June, Group-IB experts discovered a malicious application that is the Buhtrap loader.

We also revealed that hackers used the Buhtrap loader to download the RTM banking Trojan. The identified attacks targeted legal entities in Russia.

Threat name	Detection	Regions attacked
BackSwap	March 2018	Poland

Security experts from ESET have discovered a new banking Trojan called BackSwap, which uses new techniques to bypass anti-virus solutions and steal money from bank clients. The Trojan has been detected in spam emails for users in Poland. Its targets include PKO Bank Polski, Bank Zachodni WBK S.A., mBank, ING, Pekao.

BackSwap works with elements of Windows graphical interface and simulates keystrokes in order to avoid detection and bypass the browser protection. The hackers who developed BackSwap were identified in January 2018, when the group was still distributing its earlier malware, e.g. a program stealing cryptocurrency by replacing wallet addresses in the clipboard.

Unlike other banking Trojans, BackSwap does not inject malicious code into browser processes, because it can be easily detected by anti-virus software. Instead, the malware hooks key Windows message loop events in order to inspect values of the window objects for banking activity. Once banking activity is detected, the malware injects malicious JavaScript into the web page, either via the browser's JavaScript console or directly into the address bar.

Security experts at Polish CERT believe that the malware is based on Tinba source code.

Attacks on ATMs and POS terminals

Threat name	Detection	Related notifications	Regions attacked
Treasure Hunter	2014	CP-1679	Global

Information about Treasure Hunter, a malicious program for POS terminals, first appeared in 2014.

Its modus operandi is similar to all POS Trojans: the malware obtains data from the magnetic stripe of a victim's card (Track1 + Track2) from the memory of an infected POS terminal and then transfers this information to the C&C server. In 2015-2016, this malware was used for attacks on small banks and retail companies in the US.

On April 6, 2018, a user with the nickname "crossair" published an archive with the Treasure Hunter source code on the underground resource "exploit.in". In spite of the fact that the malware is quite old, its publication may lead to an increase in attacks on POS terminals, appearance of new modifications and the growth of compromised data and thefts respectively.

Threat name	Detection	Related notifications	Regions attacked
Cutlet v2	May 2018	CP-1592-2	Global

On May 28, 2018, a user nicknamed sl111 published an ad offering source code of a new ATM Trojan called Cutlet v.2. The malware is designed to attack Wincor ATMs. Based on the ad text, Cutlet v.2 has virtually the same functional capabilities as its predecessor – Cutlet Maker. The only difference is that now there is no need to generate activation passwords (previously, they were generated with a special code generator). The price is $5,000. The pack includes source code, documentation and instructions.

It is worth reiterating that Cutlet Maker and its versions are being actively used to attack ATMs worldwide. In particular, in Q2 these attacks were discovered in Portugal and Argentina.

Threat name	Detection	Related notifications	Regions attacked
ATMRipper / ATMRipper2	2016	CP-1684	Global

A malicious program for ATMs dubbed ATMRipper was first used to commit thefts in Thailand and Hong Kong in 2016. In April 2018, a new Trojan was revealed. Through analysis of this newly discovered sample, Group-IB specialists revealed that it was written based on the ATMRipper code. We named the new sample ATMRipper2.

Analysis showed that, compared to older versions, the new file includes less code and does not contain many functions that could affect its detection (file management, network activity, creating system services, terminating processes, ensuring persistence in the system).

Threat name	Detection	Related notifications	Regions attacked
xfs_test	May 2018	CP-1708	Russia

In May 2018, an unknown group launched an attack on ATMs in Russia. Threat actors used a unique program to control dispensers (the identified file was named xfs_test.exe). ATMs of different manufacturers suffered the attack.

After penetrating the network hackers used a set of PowerSploit scripts and the Radmin remote control tool. The Metasploit framework was used for initial navigation across the network.

The detected malicious program allows the hacker to use XFS API in order to connect to an ATM dispenser and send commands to deplete cash cassettes.

The provisional hypothesis is that the MoneyTaker hacker group may have been behind this attack.

State-sponsored APT groups

GROUP IB

GLOBAL CYBER SECURITY COMPANY

APT name	Regions attacked	Related notifications	Operation start
Targeted attack using Buhtrap	CIS	CP-1709	June 2018

In June 2018, researchers discovered a malicious application named "riza.exe", which is a Buhtrap loader. Hackers used a domain registered in April, 2018, as the C&C server. In addition to the main domain, several other domain names with the same registration date were found on the server.

All domains have similar names with Russian legitimate resources in the RU domain zone. Purportedly, the attack was targeting the CIS countries. The legitimate resources were related to proper nutrition, children, recipes and make-up.

Analysis showed that 2 domains contained a JavaScript that could potentially be used to load and start the Buhtrap loader. This scheme of attack had been previously used by a criminal group that employed the leaked Buhtrap source code to attack legal entities in August 2017.

Buhtrap is a Trojan used by the Buhtrap group. In February 2016, the source code leaked, which led to the appearance of modifications to the program. The malware has capabilities to replace pages in the IE browser, bypass AV solutions, use digital signatures, infect corporate networks with BuhtrapWorm, capture keystrokes, detect sandboxes and virtual machines, and get information about the connected smart cards.

APT name	Regions attacked	Operation start
Thrip	United States and Southeast Asia	2017

In June 2018, security researchers from Symantec uncovered the reemerged Thrip campaign. This most recent wave of attacks, which began in 2017, breached the systems in the United States and Southeast Asia. Symantec said the hackers launched their campaign from three computers in China.

In January 2018, the group launched malicious actions against a telecoms operator in Southeast Asia. In this campaign hackers used PsExec, which is primarily used by the attackers to move laterally across a victim's network, and a new malicious program tracked as Infostealer.Catchamas. In addition, they attempted to install an improved version of Trojan.Rikamanu.

The satellite operator wasn't the only communications target Thrip was interested in. The group had also targeted three different telecoms operators, all based in Southeast Asia. In all cases, based on the nature of the computers infected by Thrip, it appeared that the telecoms companies themselves and not their customers were the targets of these attacks.

In addition, there was a fourth target of interest, a defense contractor.

Thrip also attacked another organization involved in geospatial imaging and mapping. The hacking group targeted computers running MapXtreme GIS (geographic information system) software, which is used for tasks such as developing custom geospatial applications or integrating location-based data into other applications. It also targeted machines running Google Earth Server and Garmin imaging software.

Researchers note that the group seems to be particularly interested in the operational side of satellite communications, looking for and infecting computers running software that monitors and controls satellites.

To hide their activity and complicate attribution, hackers used the legitimate tools: PsExec, PowerShell, Mimikatz, WinSCP, LogMeIn.

In addition to legitimate tools, the group employed the following malware: Trojan.Rikamanu — a custom Trojan designed to steal information from an infected computer; Infostealer.Catchamas — based on Rikamanu, this

malware contains additional features designed to avoid detection; Trojan.Mycicil — a publicly available keylogger.

A Chinese-linked APT group, dubbed 'Thrip', has been around since 2013. The group has altered its tactics moving from only using proprietary malware to adding in some open source and publicly available tools.

APT name	Regions attacked	Operation start
OceanLotus	China, Vietnam, Cambodia, Thailand	April 2018

From April to June 2018, the OceanLotus Group hit targets in Southeast Asia and China. The criminals distributed malicious documents exploiting the CVE-2017-11882 and CVE-2017-0199 vulnerabilities.

Researchers at Tencent, malicious documents in the RTF format were distributed through phishing emails. The decoy file named "Document_GPI Invitation-UNSOOC China.doc" contained a blurred image. The hackers purportedly targeted government agencies and enterprises in China.

Once the CVE-2017-11882 vulnerability is exploited, 3 files (MicrosoftWindowsDiskDiagnsticResolver.exe, OUTFLTR.DAT and rastls.dll) are placed in a separate directory. The executable file has a valid digital signature and is used to load a DLL file. This dll will load the OUTLFLTR.DAT file and decrypt it. Following this, a library will be loaded from the resources, which will load a backdoor. The backdoor contains: C&C data, the configuration information of the Trojan's C&C and three communication-related DLLs. The Trojan uses DGA (Domain Name Generation Algorithm) to generate subdomains during communication. All information is transmitted from the infected system to the C&C server in an encrypted form. The Trojan capabilities include manipulations with the file system, creating and deleting files or directories; remote code execution; creation of processes; launching libraries; modification of the registry; setting system variables.

In early June 2018, an independent researcher Jacob Soo (@_jsoo_) discovered a similar decoy document called "2018 Cambodia Outlook Conference.doc_doc", related to the conference held in Cambodia on March 15, 2018. Despite the fact that a malicious sample was discovered in public sources in early June, the incident likely occurred in March on the eve of the conference.

Another detected sample named "Registration Form THAILAND.docx" exploits the CVE-2017-0199 vulnerability to download a document containing the exploit for CVE-2017-11882. Once the file is executed, the malware shows an error message about insufficient memory or disk space to display the image. The exploitation of the vulnerability results in the loading of several malicious executable files.

According to the FireEye specialist Nick Carr (@ItsReallyNick), in May 2018, OceanLotus launched a new intrusion operation. One of the malicious documents was discovered in Vietnam.

OceanLotus (aka APT32, APT-C-00, SeaLotus, Cobalt Kitty) is believed to be a Vietnam-based APT group that has been around since late 2009. The group typically targets companies, individuals and government networks of interest to the Vietnamese government in East-Asian countries, particularly Vietnam, the Philippines, Laos and Cambodia, as well as Germany and the United States. The list of targeted entities includes government agencies, human rights organizations, oil exploitation entities, and banks.

APT name	Regions attacked	Operation start
APT37	North Korea, South Korea	April 2018

In April 2018, the APT37 group sent out phishing emails targeting user in South Korea as part of the 'Operation Baby Coin'. The threat actor distributed a Korean-language malicious file named 'Coin info .DOC'. The document exploited the CVE-2017-11882 vulnerability to install additional malicious components. The attackers used

malicious programs to steal personal data (email accounts, social media credentials, etc.); collect and extract files with a specific extension; collect system information; capture keystrokes.

In late May 2018 Cisco Talos Intelligence Group discovered a phishing campaign distributing a new malicious Hangul Word Processor (HWP) document targeting Korean users. Once opened, the malicious document drops a remote access Trojan dubbed "NavRAT", which can perform various actions on the victim's machine, including command execution, and has keylogging capabilities. The command and control (C2) infrastructure is very specific. It uses the legitimate Naver email platform in order to communicate with the attackers via email. The uploaded file(s) are sent by email, and the downloaded files are retrieved from an email attachment.

The decoy document is named "미북 정상회담 전망 및 대비.hwp" (Prospects for US-North Korea Summit.hwp). The HWP file format is mainly used in South Korea. An Encapsulated PostScript (EPS) object is embedded within the document in order to download and execute an additional payload hosted on a compromised website: NavRAT. Once executed, NavRAT copies itself to an AhnLab folder, masquerading as a Google update. It uses the path of a well-known security company located in South Korea named AhnLab.

The malware uses the Naver email platform in order to communicate with the operators. However, researchers discovered that NavRAT was unable to communicate with the email address. The broken communication was due to protection implemented by Naver. The malware was presumably executed from too many different countries, and the account is currently locked.

Researchers at Cisco Talos Intelligence Group note that the attack is linked to APT37 but do not directly attribute the incident to this group.

APT37 (aka Reaper, Red Eyes, Geumseong121, Group123 and ScarCruft) has been active since at least 2012.

APT name	Regions attacked	Operation start
Tick	South Korea	2016

In June 2018, Palo Alto Networks discovered that the Tick group targeted a specific type of secure USB drive created by a South Korean defense company. Specialists say that the weaponization of a secure USB drive is likely done in an effort to spread to air-gapped systems, which are systems that do not connect to the public Internet. The research shows that the malware used in these attacks will only try to infect systems running Microsoft Windows XP or Windows Server 2003. The compromised USB drives are supposed to be certified as secure by the South Korea's IT Security Certification Center.

First, the attacker tricks users with a Trojanized version of legitimate software to install the loader program named "SymonLoader". When executed, the loader starts monitoring storage device changes on a compromised machine. If SymonLoader detects the targeted type of secure USB drive, it attempts to access the storage. Then, it accesses a predefined location of the storage on the USB, extracts an unknown PE file and executes it on the compromised system.

Security specialists also discovered that the Tick group Trojanized a legitimate Korean-language app, which drops the embedded malware called HomamDownloader in order to covertly install other malicious files from the remote C2 server.

Tick (aka bronze butler, redbaldknight) is a China-based threat actor. The cyberespionage group primarily targets organizations in Japan and the Republic of Korea, including biotechnology, electronics manufacturing, and industrial chemistry entities and government agencies.

APT name	Regions attacked	Operation start
Mustang Panda	USA, Mongolia	2017

In April 2017, CrowdStrike observed a previously unattributed actor group targeting a U.S.-based think tank. Further analysis revealed a wider campaign with unique tactics, techniques, and procedures (TTPs). This adversary, dubbed MUSTANG PANDA, targeted non-governmental organizations in general, but used Mongolian language decoys and themes, suggesting this actor had a specific focus on gathering intelligence on Mongolia. These campaigns involved the use of Chinese-linked malware Poison Ivy and PlugX.

In June 2018, CrowdStrike observed new activity from MUSTANG PANDA, using a unique infection chain to target likely Mongolia-based victims. This newly observed activity uses a series of redirections and fileless, malicious implementations of legitimate tools to gain access to the targeted systems.

The infection chain used in this attack begins with a weaponized link to a Google Drive folder, obfuscated using the goo.gl link shortening service. When contacted, the Google Drive link retrieves a zip file, which contains a .lnk file obfuscated as a .pdf file using the double extension trick. This file requires the target to attempt to open the .lnk file, which redirects the user to a Windows Scripting Component (.wsc) file, hosted on an adversary-controlled microblogging page. The .lnk file uses an embedded VBScript component to retrieve a decoy PDF file and a PowerShell script from the adversary-controlled web page. The PowerShell script creates a Cobalt Strike stager payload and downloads an XOR-encoded Cobalt Strike beacon payload. The Cobalt Strike Beacon implant beacons to the command-and-control (C2) IP address, which is used to remotely control the implant.

Mustang Panda is a China-based adversary that has been active since at least April 2017.

APT name	Regions attacked	Operation start
Charming Kitten	USA, Germany	2017

In June 2018, CrowdStrike experts discovered websites compromised by Charming Kitten. Hacked resources were involved in watering hole attacks. Malicious code inserted into breached websites points to the IP address that had been used by the attackers in previous attacks. Security specialists detected a compromised website of The Jewish Journal, one of the world's leading Jewish news sites, as well as websites imitating the sites of Deutsche Welle (a media company) and Frost & Sullivan (a consulting company).

Charming Kitten (aka Parastoo, iTittens, MacDownloader, NEWCASTER, NewsBeef, APT33, Group 83) has been operating since 2014 and is allegedly connected with the Iranian government. The group uses watering hole attacks and fake social media profiles, primarily targeting individuals of interest to Iran, who are involved in academic research, human rights, and the media.

APT name	Regions attacked	Operation start
Orangeworm	Global	2015

In April 2018, Symantec identified a previously unknown group called Orangeworm that has been conducting targeted attacks on the healthcare sector and related industries since 2015. Known victims include healthcare providers, pharmaceuticals, IT solution providers for healthcare and equipment manufacturers that serve the healthcare industry, likely for the purpose of corporate espionage. Some experts suggest that the ultimate goal of the attackers could be the theft of medical organizations' patents and their subsequent resale on the black market.

Once Orangeworm has infiltrated a victim's network, they deploy Trojan.Kwampirs, a backdoor Trojan that provides the attackers with remote access to the compromised computer. The malware was found on machines which had software installed for the use and control of high-tech imaging devices such as X-Ray and MRI machines. Additionally, Orangeworm was observed to have an interest in machines used to assist patients in completing consent forms for required procedures. When executed, Kwampirs decrypts and extracts a copy of its main DLL payload from its resource section. Before writing the payload to disk, it inserts a randomly generated string into the middle of the decrypted payload in an attempt to evade hash-based detections. To ensure

persistence, Kwampirs creates a service to ensure that the main payload is loaded into memory upon system reboot.

The backdoor collects basic information about the compromised computer including system version information, and language settings. Orangeworm likely uses this information to determine whether the system is used by a researcher or if the victim is a high-value target. Once Orangeworm determines that a potential victim is of interest, it proceeds to aggressively copy the backdoor across open network shares to infect other computers. At this point, the attackers proceed to gather as much additional information about the victim's network as possible, including any information pertaining to recently accessed computers, network adapter information, available network shares, mapped drives, and files present on the compromised computer. The experts observed attackers run a wide range of commands within the compromised systems to collect these data.

Orangeworm has been active since 2015, primarily targeting the healthcare sector in the United States, Europe, and Asia. Their auxiliary targets come from manufacturing, information technology, agriculture, and logistics industries.

APT name	Regions attacked	Operation start
APT28	Global	2014

In early May 2018, LoJack samples pointing to the C&C servers of the APT28 group were discovered. LoJack is a legitimate laptop recovery solution used by companies looking to protect assets should they be lost or stolen. Proof of concept in using Lojack as a backdoor or intrusion vector date back to 2014. The Lojack agent protects the hardcoded C2 URL using a single byte XOR key; however, according to researchers it blindly trusts the configuration content. Through minor modifications of this value, the attackers forced the LoJack software to communicate with its C&C instead of the legitimate server. As a result of capturing the connection used by LoJack, hackers obtained backdoor access with the ability to read memory and write on machines with running software. Five LoJack agents discovered by the experts were pointing to four C&C servers, three of which have been associated with past campaigns conducted by the APT28 group.

In June 2018, Palo Alto Networks specialists observed instances of the APT28 group leveraging the Dynamic Data Exchange (DDE) exploit technique to deliver Zebrocy and Koadic tools in attacks on government organizations dealing with foreign affairs (North America, Central Asia). As part of this campaign, attackers have moved away from their standard spear-phishing scheme: the attackers sent phishing emails to an exponentially larger number of individuals. Their email addresses were found easily using web search engines.

One of the attacks appears to have been targeting a North American government organization dealing with foreign affairs. A decoy document is deployed in this attack, with the contents purporting be a publicly available document from the United Nations regarding the Republic of Uzbekistan. The attackers leveraged DDE to retrieve and install a payload onto the victim host.

The creator of the weaponized document appended their DDE instructions to the end of the document after all of the decoy contents. When the document is opened in Word, the instructions are not displayed to the user until the "Toggle Field Codes" feature is enabled. The DDE instructions download and execute a Zebrocy AutoIt downloader, configured to attempt to download an additional payload. Then the system information about the victim is transferred to the C&C server. The malware has the ability to download and run additional files on the infected machine.

Specialists also detected that in another attack on a Central Asian state, the APT28 group leveraged DDE and loaded the Koadic tool, instead of the Zebrocy payload. Koadic is a Windows post-exploitation rootkit. It performs most of its operations using Windows Script Host.

The group APT28 (Fancy Bears, Sofacy, Pawn storm, Sednit and Strontium), first discovered in 2004, has been associated with many attacks against political, information and military targets around the world.

APT name	Regions attacked	Operation start
Targeted attack on a U.S. Navy contractor by Chinese hackers	Newport (USA)	January 2018

In June 2018, it was reported that Chinese hackers attacked a contractor who works for the Naval Undersea Warfare Center. The breached occurred in January and February 2018. Taken were 614 gigabytes of sensitive information relating to a closely held project known as Sea Dragon, which provides for the development of a supersonic anti-ship missile for use on US submarines by 2020 as well as signals and sensor data, submarine radio room information relating to cryptographic systems, and the Navy submarine development unit's electronic warfare library. The breach is part of China's long-running effort to blunt the US advantage in military technology.

APT name	Regions attacked	Operation start
MuddyWater	Turkey, India, Pakistan and Egypt	April 2018

In early May 2018, an independent researcher, Mo Bustami, analyzed new malware samples used in phishing attacks on organizations in Turkey, Iraq and Pakistan in April and May 2018.

The decoy document, used in the attacks, mimicked government organizations and telecommunication companies to trick victims into enabling macros. The macro then drops the POWERSTATS backdoor. The backdoor collects machine information, takes screenshots, loads and executes additional PowerShell scripts. It also has capabilities to reboot and shut down machines, delete files from the file system, encrypt uploaded information, detect security tools, test environments and code analysis tools.

Researchers noted that the screenshot function was re-written, although its purpose remained unchanged. Also there was a call function BSOD, which in fact is one of the ways to bypass the analysis mechanisms. The developers included a Blue Screen of Death or BSOD code as an anti-debugging and anti-analysis technique. This is an exact copy of Invoke-BSOD code that was created by Barrett Adams (@peewpw) and is available on his GitHub page.

In May 2018, researchers discovered a malicious document named "Egyptairplus.doc", which may have been part of the MuddyWater campaigns. The document features numerous ties to the previously observed MuddyWater decoy documents. However, security specialists did not clearly attribute the attack to the threat actor.

A new decoy document is a Word file disguised as a document of a commercial organization. It contained a built-in macro that launched the PowerShell script, downloading a backdoor. Unlike previous attacks, the samples don’t attempt to download the VBS and PowerShell scripts, but have them encoded in the document itself. Another difference from previous MuddyWater campaigns is that PRB-Backdoor was installed on the victim's machine instead of POWERSTATS. Based on the received instructions, the backdoor can initialize a connection with the C&C, whose address is specified in a special variable, gather browsing history from installed browsers and send it to the C&C, steal passwords found in the browser, read and write files, execute shell commands, log keystrokes, capture screenshots, and gather system information.

MuddyWater (aka TEMP.Zagros) is an Iran-nexus threat actor that has been active since at least February 2017. They are targeting government and defense entities, oil and telecommunications companies.

APT name	Regions attacked	Operation start
Iron Tiger	Mongolia	October 2017

In June 2018 Kaspersky Lab reported that they detected an ongoing campaign targeting a national data center in the Central Asia that has been active since the autumn of 2017. According to CyberScoop, Mongolia suffered this attack. Through this attack, hackers accessed a wide range of government websites and injected malicious JavaScript code into them.

To gain initial access to the data center, attackers conducted "watering hole" attacks and sent spear-phishing emails with weaponized documents exploiting the CVE-2017-118822 vulnerability.

Iron Tiger used the HyperBro Trojan as their last-stage in-memory remote administration tool (RAT). The threat actors employed Metasploit's shikata_ga_nai encoder, which is regularly used by a variety of Chinese-speaking actors, as well as LZNT1 compression.

The main C&C used in this campaign is an IP address that belongs to the Ukrainian ISP network, held by a Mikrotik router using outdated firmware. Hacked equipment allows threat actors to hide the actual address of the C&C server.

The Iron Tiger group (aka Emissary Panda, Threat Group-3390, LuckyMouse, APT27) has been active since 2010, performing attacks from China.

APT name	Regions attacked	Operation start
APT15	Global	June 2018

In June 2018, researchers at security firm Intezer discovered evidence of very recdent activity by the APT15 group. According to their blog, the malware involved in a recent campaign, MirageFox, looks to be an upgraded version of a tool, a RAT believed to originate in 2012, known as Mirage. New samples were discovered based on the YARA rules created for Mirage and Reaver.

MirageFox borrows code from both Mirage and Reaver malware. For example, similar to Reaver, MirageFox has the function for decrypting the data containing the C&C configuration. Analysis of the decrypted configuration shows the IP being used for the C&C is an internal IP address on the victim company's network, which means that the sample was specifically configured for the targeted organization and that the attackers connected to the victim's internal network using a VPN.

APT15, aka Ke3chang, Mirage, Vixen Panda GREF and Playful Dragon, has been tied to espionage campaigns against Indian embassy personnel in 2016, and the attack targeting European diplomats and ministries of foreign affairs discovered in 2013. Attackers are believed to be operating from China.

APT name	Regions attacked	Operation start
Andariel	South Korea	January 2017

According to the researcher Simon Choi (@issuemakerslab), the Andariel group conducted a campaign that began in a reconnaissance stage in 2017. Since January 2018, cybercriminals have conducted a series of "watering hole" attacks. The attacks targeted the Sejong Institute, a non-profit South Korean think tank which conducts research on national security. According to Bleeping Computer, at least nine separate ActiveX vulnerabilities were recorded in the May wave of attacks. A South Korean security researcher told Bleeping Computer that the ActiveX zero-day used by Andariel is connected to attacks on Samsung SDS Acube installations.

Hackers initially deployed a profiling script used to scrape information on potential targets. The next step of the attack involved scripts capable of gathering additional information from the system and designed to deliver the ActiveX exploit. The script identifies the browser and operating system running on the victim's machine. Alien

Vault reports that this script borrows much of the code from PinLady's Plugin-Detect, a JavaScript library that detects browser plugins. When detecting Internet Explorer on a machine, the script checks if ActiveX is enabled, as well as plugins running (from a specific list of ActiveX components). An additional payload containing malware is then downloaded and executed. The malware, dubbed "Akdoor.R228914" by South Korean cybersecurity firm AhnLab, is a simple backdoor which executes commands over the command prompt.

In total, three watering hole exploits were deployed on the domain this year. On April 18 - 19, 2018, an ActiveX zero-day exploit was injected. The next injection was performed on April 23. The last detected injection was on May 7-8; unlike previous cases, the embedded code was obfuscated.

Andariel (aka Silent Cholima) is a North Korean hacking group, which is believed to be a division of the Lazarus APT Group.

APT name	Regions attacked	Operation start
Kimsuky	South Korea	May 2018

In May 2018, the Kimsuky group distributed malicious HWP documents as part of the 'Operation Onezero'. Security researchers at ESTsecurity have analyzed a malicious document named "종전 선언 '이고", which refers to the peace treaty signed between North and South Korea. The sample was created on May 14, 2018, which is believed to be the date when the phishing campaign started. The document is password-protected against editing and contains a text about North Korea's nuclear programme, the military crisis and other content designed to mislead the victim.

A shellcode discovered in the document is almost identical to the sample discovered in 2014. The shellcode created the core.dll file and injected it into the legitimate notepad.exe process. Following this, additional modules were installed on the system. The 'fontchk.jse' file were added to the startup and run via the 'wscript.exe' command. Google Drive was used as a command-control (C2) server in the attack. The 'fontchk.jse' file connected to specific Google Drive URL addresses and downloaded 'brid.mki' and '7za.exe' files. The 'brid.mki' file is an encrypted compressed ZIP file, which contains the 'brid.ige' file. The '7za.exe' file is a 7-Zip Standalone Console program that is downloaded to extract the archive.

By using the key stored in the fontchk.jse file, the brid.ige file is unpacked. In addition, by adding a script command, it attempted to connect to a specific host in the Netherlands.

Kimsuky is a hacker group, purportedly operating from North Korea. Since 2010, the group has been actively attacking facilities in South Korea. Their attacks appear related to the APT37 group (aka Geumseong121) because they share similar indicators of compromise.

APT name	Regions attacked	Operation start
Lazarus	South Korea, Global	2017

In May 2018, US authorities published another report on the Lazarus group detailing the Joanap backdoor Trojan and the Brambul worm. These Trojans have been used by hackers since June 2009 to launch attacks against critical infrastructure sectors, media organizations, aerospace and financial industries across the world. The new study says that in 2017-2018 Lazarus began to use their new versions.

Joanap is a fully functional RAT that is able to receive multiple commands, which can be issued by threat actors remotely from the C&C server. The malware typically infects a system as a file delivered by other malware, which users unknowingly download either when they visit websites compromised by the Lazarus actors, or when they open malicious email attachments. Joanap allows cybercriminals to install and run additional payloads, initialize proxy communications on a compromised Windows device, manage files and processes, create and delete

directories, and manage nodes. Specialists noted that the Trojan the malware encodes data using Rivest Cipher 4 encryption to protect its communication with threat actors.

Through analysis of the Joanap infrastructure, the malware was found on 87 compromised network nodes in 17 countries. The nodes with infected IP addresses are registered in such countries as Argentina, Belgium, Brazil, Cambodia, China, Colombia, Egypt, India, Iran, Jordan, Pakistan, Saudi Arabia, Spain, Sri Lanka, Sweden, Taiwan, and Tunisia.

Brambul malware is a malicious Windows 32-bit SMB worm that functions as a service dynamic link library file or a portable executable file often dropped and installed onto victims' networks by dropper malware. When executed, the malware attempts to establish contact with victim systems and IP addresses on victims' local subnets. If successful, the application attempts to gain unauthorized access via the SMB protocol (ports 139 and 445) by launching brute-force password attacks using a list of embedded passwords. Additionally, the malware generates random IP addresses for further attacks.

Once the malware establishes unauthorized access on the victim's systems, it communicates information about victim's systems to Lazarus hackers using malicious email addresses. This information includes the IP address and host name—as well as the username and password—of each victim's system. Threat actors can use this information to remotely access a compromised system via the SMB protocol.

In June 2018, 11 samples of a new malware called TypeFrame were reportedly detected. Most of the samples are simple 32-bit and 64-bit remote access Trojans with RC4-encrypted configuration files. The C&C servers involved in the campaign are located in the USA, Morocco, China, Dubai, Albania, Mexico and India.

Lazarus was also reported to be targeting members of a recent G20 Financial Meeting, seeking coordination of the economic policies between the wealthiest countries. The HWP documents used in these attacks include a malicious postscript code that downloads the second stage malware (either a 32 or 64 bit version of Manuscrypt).

The Lazarus group, also known as Dark Seoul Gang/HIDDEN COBRA/Guardians of Peace started its operations back in 2007. Members of this group are believed to originate from North Korea.

Threats to blockchain projects and cryptocurrencies

GROUP IB

GLOBAL CYBER SECURITY COMPANY

Company attacked	Location	Attack date
Coinsecure cryptocurrency exchange	India	April 2018

CSO at Coinsecure, an Indian cryptocurrency exchange, has been accused of the theft of $3.5 million in bitcoins. The suspect claims that the money was stolen from the company's bitcoin wallet due to some attack. CEO of the cryptocurrency exchange does not believe his subordinate and thinks that it is just a story invented to throw off suspicion. In order to find the criminals, the cryptocurrency exchange offers about INR 20 million to any users who help it find the stolen tokens. The recent hacking of Coinsecure affected about 11,000 people.

Company attacked	Location	Attack date
MyEtherWallet	USA	April 2018

In late April, MyEtherWallet, one of the largest Ethereum wallets, has reportedly been the victim of a DNS hack. MyEtherWallet spokesmen have confirmed that some DNS servers had been hijacked by the criminals to redirect users to a phishing website. The administration reassured users that the problem did not occur on the service side. According to the company's official message on Twitter, they are currently 'in the process of verifying which servers to get it resolved asap'.

APT name	Regions attacked	Operation start
Targeted attack on the Taylor cryptocurrency trading app	Global	May 2018

On May 21, 2018, the Taylor cryptocurrency trading app was hacked. The funds stolen from the Taylor team come from the company's recently completed initial coin offering (ICO) round. The team said that all of their funds had been stolen, including the balance in ETH (2,578.98 ETH), which equates to approximately $1.5 million, but also the TAY tokens from the Team and Bounty pools. Researchers believe that the hacker is the same person/group who stole over 17,000 Ether ($9 million) from the CypheriumChain project back in March, as this is the same address to which both sets of stolen funds have ended up.

Soon after discovering the hack, the Taylor team says it also noticed an attempt to dump some of the stolen TAY tokens and exchange them for other cryptocurrencies. Developers asked the IDEX platform, where these tokens can be traded, to delist TAY tokens for the time being, in an attempt to prevent the hacker from monetizing the entirety of the stolen funds.

APT name	Regions attacked	Operation start
Targeted attack on the OKEx trading platform	China	April 2018

On April 22, 2018 the OKEx trading platform based in Hong Kong, was compromised by unidentified hackers. According to PeckShield, a blockchain security company, someone transferred an extremely large amount of BEC token. PeckShield explains that such abnormal BEC trading activities comes from an "in-the-wild" attack that exploits a previously unknown vulnerability CVE-2018-10299 in the smart contract. This vulnerability, called batchOverflow, is essentially a classic integer overflow issue. A line in the smart contract creates another value — amount — by multiplying cnt and _value. The hackers made a transfer and set the value to eight vigintillion — an eight with 63 zeroes. When this value is passed, the code overflows, allowing the hacker to gain a massive number of tokens. Thanks to the smart contract's "code-is-law" principal, each of these transfers are technically legitimate.

OKEx made an announcement to suspend the withdrawal and trading of BeautyChain (BEC), a batchOverflow-affected token.

APT name	Regions attacked	Operation start
Targeted attack on Bitcoin Gold networks	Global	May 2018

On May 16-18, 2018, unknown hackers attacked the Bitcoin Gold cryptocurrency network. To carry out the attack, the miner captured at least 51% of the computing power of the network, which allowed him to temporarily control the blockchain. Having gained control over the network, the attacker began making deposits in BTG to the exchange of cryptocurrencies, while sending the same coins to his own wallet. In a normal situation, the blockchain company would not accept a second transaction, since the transfer of these coins would already be accounted for and recorded in the block, however, having the ability to manipulate the network, the attack organizer included only those transactions that he needed to the final version of the blockchain.

Thus, he made deposits to exchanges, then immediately withdrew funds and canceled the original transaction, accumulating the cryptocurrency at a separate address.

A total of 388,200 BTC has been stolen, which equals $18.6 million worth of funds.

APT name	Regions attacked	Operation start
Targeted attack on ZenCash network	Global	June 2018

ZenCash (ZEN), a platform designed for secure communications and private economic activity, saw its network suffer a 51% attack on June 2, 2018. In less than 4 hours, hackers made $550,000 by using double spend transactions by reorganizing 38 units of the blockchain. The first double spend was 6600 Zen, while the second double spend was 13,234.9 Zen. According to Crypto51, a website which estimates the theoretical cost of a 51% attack on various cryptocurrencies, it cost the attacker around $30,000.

APT name	Regions attacked	Operation start
Targeted attack on the Litecoin Cash network	Global	June 2018

In early June 2018 Litecoin Cash was hit with a 51% attack. Litecoin Cash is the “hard fork” of Litecoin (LTC), the fifth largest cryptocurrency on the market. The extent of the damage is unknown.

The Litecoin Cash team acted fast on news of the attack and contacted exchanges immediately, increasing the block confirmation level to 100 to make it more difficult for one to control.

APT name	Regions attacked	Operation start
Targeted attack on the cryptocurrency exchange Coinrail	South Korea	June 2018

South Korean cryptocurrency exchange Coinrail reported a hack on its website during the early morning hours of June 10, 2018. Coinrail’s daily trading volume is roughly $2.5 million. Though it is technically one of the smaller digital currency exchanges, Coinrail still ranks among the top 100 across the globe according to Coinmarketcap.com.

Coinrail reportedly lost cryptocurrencies totaling as much as $40 million in the attack. The hackers stole around $19.5 million in NPXS tokens, $13.8 million in Aston X tokens, $5.8 million in Dent tokens, and $1.1 million Tron/TRX. Executives announced that roughly 30 percent of the tokens the exchange was housing have been taken. Two-thirds of stolen cryptocurrencies were withdrawn or frozen in partnership with related exchanges and coin companies. For the rest, the investigative activities are ongoing.

Coinrail tweeted that it is in the process of restructuring its business in order to resume service around July 15, 2018.

APT name	Regions attacked	Operation start
Lazarus	South Korea, Global	March 2018

On March 26, 2018, the Lazarus group launched a new wave of attacks on customers of South Korea's crypto-exchange exchanges. Specialists at ESTsecurity called the campaign 'Operation Battlecruiser'. Lazarus leveraged a vulnerability in HWP to conduct the attack. On March 26, 2018, hackers created a malicious document and a binary file to be downloaded once a vulnerability is detected. Attackers registered the "naviilibs.com" phishing site, from which malicious .AVI files "battle32.avi" and "battle64.avi" were downloaded.

In April 2018, Lazarus conducted a campaign called 'Operation Starcruiser'. Attackers sent phishing emails, exploiting a vulnerability in HWP. The document was created on April 10, 2018. Analysis of the metadata showed that the author of the document is named "TATIANA". After exploiting the vulnerability, the files "star3.avi" and "star6.avi" were downloaded to the victim's computer. To communicate with the C&C servers, the malware uses the command *dJU!*JE&!M@UNQ@, which is similar to their campaign "Operation Battlecruiser". Victims of attacks, purportedly, are clients of cryptocurrency exchanges.

Hackers continued their attacks in June 2018, targeting South Korean users. Attackers sent emails from the address registered in Naver (the largest Internet portal and the most popular search engine in South Korea). Cybercriminals once again exploited the vulnerability in HWP. Although files and emails are related to military and government issues, the attack again targeted clients of cryptocurrency exchanges.

During the night, June 19-20 (Korean time), the South Korean cryptocurrency exchange "Bithumb" was attacked. Bithumb is one of the largest stock exchanges in Asia with a daily trading volume of $270 million. Once the attack was detected, Bithumb suspended all trading and moved the remaining crypto assets off line to cold storage. It was reported that the financial losses of the exchange amounted to $31 million. The exchange has not yet disclosed full details of the stolen coins, but promised to reimburse all losses to its customers from its own funds. Bithumb asked customers not to deposit any fund into Bithumb wallet addresses for the time being.

Through investigation of the attack on Bithumb, experts at Alien Vault discovered a decoy document disguised as a resume, which was similar to the documents used in previous attacks by Lazarus. The file contained malicious code that downloaded a 32- or 64-bit version of the Manuscrypt backdoor from a third-party server. Based on the above-mentioned information, some researchers attributed the attack to the Lazarus group.

The Lazarus group, also known as Dark Seoul Gang/HIDDEN COBRA/Guardians of Peace started its operations back in 2007. Members of this group are believed to originate from North Korea.

Data leakage

GROUP IB

GLOBAL CYBER SECURITY COMPANY

- In May, it was reported that a database containing sensitive personal data from a South African online traffic fines payments website had been leaked online. Later, security firms together with Troy Hunt, security consultant, had verified that the leaked database was that of ViewFines. The ViewFines database of close to 1 million unencrypted records of South African drivers was publicly accessible. The database contained ID numbers, full names, phone numbers, e-mail addresses, and passwords stored in plaintext.
- More than 90,000 people have been affected by cyber-attacks targeting two of the largest banks in Canada – Bank of Montreal (BMO) and Canadian Imperial Bank of Commerce's Simplii Financial (CIBC). Cyber criminals contacted them stating that they managed to obtain personal and financial information and threatened to make the data public.
- Experts at FireEye discovered the data of around 200 million Japanese users being sold on a Chinese underground cybercrime forum. The data seemingly comes from a range of 11-50 Japanese websites across industries including financial, retail, food and beverage, transportation, and entertainment. Experts believe that the consolidated archives first appeared on sale in December 2017. Specific data types included in this set include names, credentials, email addresses, birthdates, phone numbers, and home addresses. The dataset is offered for $150 only.
- Security researchers reportedly discovered 43 Million email addresses leaked by the Trik spam botnet. The content of its C&C server was accessible to anyone, the researcher discovered 2,201 text files, containing chunks of roughly 20,000 email addresses each. The majority of leaked addresses were unique.